Validation coté client :

De nombreuses applications web se fient uniquement au code JavaScript front-en pour valider le format du fichier séléctionner avant son téléversement. Cependan étant donné que la validation n'est que client-side on peu facilement la contr rner en interagissant directement avec le serveur ou en modifiant le code front- via les devtools de notre navigateur.
Un des indice d'une validation front-end est l'absence de requete lors de la sélection d fichier à téléverser, rappelons que tout code qui s'éxécute coté client est sous notre c trole... Et que il faut de la patiente pour analyser le fonctionnement de n'importe q system de securité. HACKER MINDSET c'est vraiment le plus important et encore mon point faible, très gros point faible.

Filtres Sur Liste Noire:

Nous avons donc vu que la protection coté client était très faible, il est donc essaire de l'implementer coté back-end, mais surtout de bien l'implimenter car une curité mal codée coté backend est également bypassable.
Une des sécurité généralement implementer est la liste noir d'extention... Très peu et contourner si certaines extention sont oubliés (Ex: PHp, phpT, etc)
Nous pouvons fuzzer les extention afin de découvrir laquelle parviendra a passer filtres, l'Intruder de BurpSuite est très bon outil pour se faire.
Notons que c'est pas parcequ'une extention pass le filtre que son code est exécuté, dépend de la configuration du serveur.

Filtres Sur Liste Blanches:

Ce type de sécurité à l'inverse des black list définit les extentions ayant seul le droit d'être utilisées, généralement plus sécurisé que les listes noires
S'une des façon de bypasser une white liste mal faite est par l'utilisation de double extention la dernier etant exécuté par le serveur, Exemple: shell.jpg.p
L'utilisation de certains caracteres spéciaux peux également contourner des filtre notons aussi que ce n'est pas car un fichier est uploader que son code sera exécu
Bien que l'a deuxieme Extention (dernier) est généralement celle exécuté avec un mauvaise configuration du server la premier peux également l'être.

Filtres de Type:

Nous avons vu les diverses filtres portant sur l'extention du fichier mais c tains portant sur son contenu, ou via l'entité Content-Type, ou bien avec l contenu reél du fichier tel qu'il est envoyé...
Le Content-Type est une entité souvent choisi automatiquement par l'utilisa eur coté client elle est donc entièrement manipulable, Sedlists possède une wordlis permettant de fuzzer les Content-Type.
Le deuxième type de validation de format de fichier et le plus courant se fait inspectant le format général et la structure en octet du fichier, notamment les o etes magiques (premier octet du fichier) Ex GIF87a indique qu'il s'agit d'une i age GIF. On peux donc rajouter ces octet magique au debut de notre fichier pour bypa ser les filtres, on peu utiliser la commande file qui analyse un fichier sur bas de ces octets afin de verifier la reélle nature de notre formattage
Bien sur toute ces methodes peuvent se cumuler...

Téléversement de Fichiers Limités :

Certains filtres ne nous permettrant pas d'uploader des fichiers arbitraire ma certains types de fichiers comme SVG, HTML, XML et même certaines images ou documents peuvent nous permettre d'introduires de nouvelles vulnérabilités dans application web